

**FATEC – FACULDADE DE TECNOLOGIA DE SÃO CAETANO DO SUL
ANTÔNIO RUSSO**

**ISG012 — Atividades 03 e 04: Firewalls de
Perímetro e Redes Privadas Virtuais**

Efraim de Almeida Lima

**Junho – 2026
SÃO CAETANO - SP**

ÍNDICE

1. Objetivo
2. Atividade ISG012-03 – Teoria: Firewalls de Perímetro e Filtragem Avançada
3. Atividade ISG012-03 – Prática: Configuração de Firewall com NAT e DMZ
4. Atividade ISG012-04 – Teoria: Redes Privadas Virtuais (VPN)
5. Atividade ISG012-04 – Prática: Implementação de VPN Site-to-Site com WireGuard
6. Conclusão

Objetivo

Esta atividade tem por objetivo consolidar os conhecimentos sobre firewalls de perímetro, filtragem avançada de tráfego com nftables e arquitetura de DMZ (ISG012-03), além de compreender os fundamentos das Redes Privadas Virtuais, seus protocolos (IPsec, SSL/TLS, WireGuard) e a implementação prática de uma VPN site-to-site (ISG012-04). A integração destes conteúdos capacita o aluno a projetar e implementar infraestruturas de rede corporativas seguras, com perímetro bem definido e comunicações cifradas entre filiais.

Atividade ISG012-03 – Teoria: Firewalls de Perímetro e Filtragem Avançada

Questão 1

Explique a diferença fundamental entre firewalls stateless (packet filtering) e firewalls stateful inspection, destacando as vantagens de segurança proporcionadas pela abordagem stateful.

Resposta:

Os firewalls **stateless (packet filtering)** operam na camada 3 do modelo OSI, analisando cada pacote de forma isolada e independente, baseando-se exclusivamente nos campos do cabeçalho IP e TCP/UDP: endereço IP de origem e destino, portas e protocolo. Por não manterem qualquer informação sobre conexões anteriores, não conseguem distinguir se um pacote pertence a uma sessão legítima estabelecida ou se é um pacote forjado injetado por um atacante. São rápidos e têm baixo overhead de processamento, mas são vulneráveis a ataques de IP spoofing, onde pacotes com cabeçalho IP falsificado podem corresponder a regras permissivas.

Os firewalls **stateful inspection** adicionam o conceito de tabela de estados (connection tracking table), que registra o ciclo de vida completo das conexões ativas usando o quintuplo identificador: IP origem, IP destino, protocolo, porta origem, porta destino. O firewall rastreia o handshake TCP (SYN → SYN-ACK → ACK) e associações UDP, e sabe exatamente quais

conexões estão em qual estado (NEW, ESTABLISHED, RELATED, INVALID).

As vantagens de segurança do stateful são significativas: (1) **Bloqueio de pacotes fora de contexto**: um pacote ACK sem SYN anterior correspondente é automaticamente detectado e descartado como inválido; (2) **Regra `established,related accept`**: permite respostas a conexões iniciadas internamente sem necessidade de regras bidirecionais explícitas, evitando aberturas desnecessárias; (3) **Proteção contra scanning furtivo**: técnicas como SYN scan, FIN scan e Xmas scan são detectadas por violarem o fluxo normal de estados TCP; (4) **Menor superfície de regras**: regras mais simples e precisas, reduzindo o risco de configuração incorreta.

Questão 2

Descreva o propósito e a arquitetura típica de uma Zona Desmilitarizada (DMZ) em uma rede corporativa, explicando por que servidores públicos devem ser isolados tanto da Internet quanto da rede interna.

Resposta:

A DMZ (Demilitarized Zone) é uma sub-rede intermediária de segurança que hospeda serviços públicos de uma organização — servidores web, DNS, e-mail, FTP — de forma que sejam acessíveis pela Internet sem que um comprometimento desses servidores resulte em acesso à rede interna corporativa.

A arquitetura típica utiliza **dois firewalls em série**:

Firewall externo (de perímetro): posicionado entre a Internet e a DMZ, permite apenas tráfego nas portas dos serviços públicos (80/TCP, 443/TCP, 25/TCP, 53/UDP). Todo o restante é descartado.

Firewall interno: posicionado entre a DMZ e a rede interna corporativa, é mais restritivo. Permite apenas conexões iniciadas pela rede interna em direção à DMZ (ex.: atualizações de conteúdo) e respostas a essas conexões. Bloqueia qualquer conexão iniciada a partir da DMZ em direção à rede interna.

Alternativa comum é o **tri-homed firewall**: um único firewall com três interfaces — uma para a Internet, uma para a DMZ e uma para a rede interna — com políticas distintas por interface.

Os servidores públicos devem ser isolados da rede interna porque: se um servidor web na DMZ for comprometido via exploração de vulnerabilidade (ex.: RCE em uma aplicação web), o atacante obtém controle sobre aquele servidor. Sem a DMZ, esse servidor comprometido teria acesso direto à rede interna (ERP, bancos de dados, Active Directory). Com a DMZ, o atacante enfrenta um segundo firewall para alcançar a rede interna, aumentando drasticamente a complexidade e o tempo necessário para a intrusão, dando à equipe de segurança janela para detecção e resposta.

Questão 3

Explique o funcionamento do Source NAT (SNAT) e do Destination NAT (DNAT), diferenciando suas aplicações práticas em um firewall de perímetro.

Resposta:

NAT (Network Address Translation) é uma técnica que modifica os endereços IP nos cabeçalhos dos pacotes enquanto eles transitam pelo firewall, permitindo que múltiplos dispositivos com endereços privados compartilhem um único endereço IP público.

SNAT (Source NAT): modifica o endereço IP de **origem** dos pacotes. A aplicação mais comum é o mascaramento de redes internas: quando hosts da rede interna (ex.: 192.168.1.x) acessam a Internet, o firewall substitui o IP de origem privado pelo IP público da interface externa antes de encaminhar o pacote. O firewall mantém uma tabela de tradução para associar as respostas retornantes ao host interno correto. No nftables, é implementado com a ação `masquerade` (SNAT dinâmico, ideal para IPs externos que mudam) ou `snat to <IP>` (SNAT estático para IP fixo). Aplicação prática: permitir que toda a rede corporativa acesse a Internet através de um único IP público.

DNAT (Destination NAT): modifica o endereço IP de **destino** dos pacotes. A aplicação mais comum é a publicação de serviços internos: o firewall recebe uma conexão destinada ao IP público na porta X e redireciona (port forwarding) para um servidor interno em endereço privado e porta Y. No nftables, é implementado com `dnat to <IP_interno>:<porta>` na chain PREROUTING. Aplicação prática: redirecionar conexões na porta 443 do IP público para o servidor web interno em 192.168.2.10:443; publicar um

servidor SSH interno na porta 2222 do IP público.

A diferença fundamental: SNAT opera na saída (altera quem enviou), DNAT opera na entrada (altera para onde vai). Ambos são processados antes da decisão de roteamento (PREROUTING para DNAT) ou após (POSTROUTING para SNAT).

Questão 4

Descreva como o connection tracking (conntrack) funciona em firewalls stateful e por que a regra "established,related accept" é tipicamente a primeira regra em uma chain de firewall.

Resposta:

O connection tracking (módulo `conntrack` do Netfilter) é o mecanismo que permite ao firewall Linux manter estado sobre todas as conexões de rede ativas. Para cada fluxo de pacotes, o `conntrack` registra na tabela de estados o quintuplo (IP origem, IP destino, protocolo, porta origem, porta destino) e o estado atual da conexão, que pode ser:

NEW: primeiro pacote de uma nova conexão (ex.: SYN TCP)

ESTABLISHED: pacotes pertencentes a uma conexão já reconhecida em ambas as direções

RELATED: pacotes relacionados a uma conexão estabelecida, mas não pertencentes ao mesmo fluxo (ex.: mensagens ICMP de erro referentes a uma conexão ativa, ou conexões de dados FTP iniciadas a partir de uma sessão de controle)

INVALID: pacotes que não correspondem a nenhuma conexão conhecida ou estão fora de sequência

A regra `ct state established,related accept (nftables)` ou `-m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT (iptables)` é colocada como **primeira regra na chain** por razões de performance e segurança:

Performance: a vasta maioria do tráfego em uma rede ativa consiste em pacotes de conexões já estabelecidas. Ao verificar essa condição primeiro e aceitar imediatamente esses pacotes, o firewall evita processar todas as demais regras para o tráfego de retorno mais comum, reduzindo drasticamente a latência e a carga de processamento.

Segurança: sem essa regra, o firewall precisaria de regras bidirecionais

explícitas para cada serviço, o que aumentaria a superfície de ataque. Com `established,related accept`, apenas pacotes NEW precisam ser avaliados contra regras específicas; respostas legítimas passam automaticamente.

Correção funcional: respostas a conexões iniciadas internamente (ex.: resposta HTTP a uma requisição de um usuário interno) seriam bloqueadas sem essa regra se a chain tiver política padrão drop.

Questão 5

Explique a importância da ordem das regras em um firewall e como a política padrão (default policy) afeta a segurança geral da configuração.

Resposta:

Em firewalls como `nftables` e `iptables`, as regras são avaliadas sequencialmente, na ordem em que foram inseridas, do topo para o fundo da chain. O primeiro match (correspondência) determina a ação tomada — o pacote não continua sendo avaliado pelas regras seguintes após um match. Essa característica torna a **ordem das regras crítica para a segurança**:

Regras mais específicas devem vir antes de regras mais genéricas: uma regra que bloqueia um IP específico (ex.: drop para 10.0.0.5) deve estar antes de uma regra que permite toda a sub-rede (ex.: accept para 10.0.0.0/24), caso contrário o IP específico seria aceito pela regra genérica antes de ser alcançado pela regra de bloqueio.

`ct state established,related accept` deve ser a primeira: como discutido, por performance e para não bloquear respostas legítimas.

Regras de logging antes de regras de drop: para registrar o tráfego bloqueado, a regra de log deve preceder a regra de drop para o mesmo tráfego.

A **política padrão (default policy)** define o que acontece com pacotes que não correspondem a nenhuma regra da chain. Existem duas abordagens:

Policy ACCEPT (padrão permissivo): tráfego não coberto pelas regras é permitido. Qualquer vetor de ataque não previsto nas regras de bloqueio passa livremente — extremamente arriscado.

Policy DROP (padrão restritivo / fail-safe): tráfego não coberto pelas regras é silenciosamente descartado. Implementa o princípio do menor

privilégio: apenas o que é explicitamente permitido funciona. Um erro de configuração (regra faltante) resulta em negação de serviço, não em brecha de segurança — muito mais seguro.

A boa prática é sempre usar **policy DROP** em chains de firewall de produção, adicionando apenas as regras `accept` estritamente necessárias.

Questão 6

Descreva as melhores práticas para logging em firewalls de perímetro e como os logs contribuem para a detecção de tentativas de intrusão.

Resposta:

O logging em firewalls de perímetro é fundamental para visibilidade de segurança, auditoria de conformidade e resposta a incidentes. As melhores práticas incluem:

1. Logar tráfego bloqueado com prefixos identificáveis:

```
nft add rule inet firewall forward drop log prefix "FW-DROP-FORWARD: "
```

Prefixos padronizados (ex.: "FW-DROP-INBOUND:", "FW-ACCEPT-DMZ:") facilitam filtragem automatizada e correlação em SIEMs.

2. Registrar tentativas de acesso a portas críticas:

Logar antes de aceitar ou rejeitar conexões em portas sensíveis (22/SSH, 3389/RDP, 443/HTTPS) permite detectar scanning e ataques de força bruta.

3. Centralizar logs em servidor SIEM:

Logs locais são vulneráveis à adulteração se o firewall for comprometido. O envio em tempo real para um SIEM (via syslog/rsyslog para servidor remoto) garante integridade e correlação com outros eventos.

4. Implementar alertas baseados em threshold:

Regras no SIEM que alertam quando um IP gera mais de X tentativas bloqueadas em Y minutos detectam automaticamente port scans (Nmap), ataques DDoS e brute force.

5. Retenção adequada de logs:

Legislações como LGPD e normas como PCI-DSS exigem retenção de logs por períodos específicos (tipicamente 12 meses). Logs devem ser

armazenados em formato imutável.

Contribuição para detecção de intrusão:

Port scanning: múltiplas tentativas em portas sequenciais originadas de um único IP em curto intervalo

Brute force: múltiplas tentativas de conexão na porta 22 ou 3389

Movimentação lateral: tráfego entre segmentos que normalmente não se comunicam (ex.: DMZ tentando alcançar rede interna)

Exfiltração de dados: grandes volumes de tráfego outbound para IPs externos desconhecidos

Reconhecimento: tentativas em portas de serviços não publicados (honeypot ports)

Atividade ISG012-03 – Prática: Configuração de Firewall com NAT e DMZ

Questão Prática 1

Qual comando nftables é utilizado para criar uma tabela que suporte tanto IPv4 quanto IPv6, e qual a diferença em relação a uma tabela IP específica?

Resposta:

Criar tabela dual-stack (IPv4 + IPv6):

```
nft add table inet meu_firewall
```

A família `inet` no nftables é uma família genérica que processa tanto pacotes IPv4 quanto IPv6 simultaneamente com o mesmo conjunto de regras e chains. Uma única regra escrita com endereços em notação CIDR IPv4 ou IPv6 é aplicada ao protocolo correto automaticamente.

Criar tabela exclusiva para IPv4:

```
nft add table ip meu_firewall_ipv4
```

Criar tabela exclusiva para IPv6:

```
nft add table ip6 meu_firewall_ipv6
```

Diferença prática:

Família	Cobre	Sintaxe	Recomendação
<code>`inet`</code>	IPv4 + IPv6	Unificada	✓ Preferida em ambientes modernos
<code>`ip`</code>	Apenas IPv4	Específica	Uso legado ou quando IPv6 não existe
<code>`ip6`</code>	Apenas IPv6	Específica	Uso específico IPv6

Com `inet`, uma única chain forward controla ambos os protocolos, eliminando o risco de configurações assimétrica onde IPv6 fica sem proteção enquanto regras IPv4 estão ativas — uma vulnerabilidade comum em firewalls legados com iptables (que exige `ip6tables` separado).

Questão Prática 2

Como configurar o mascaramento (SNAT dinâmico) para permitir que a rede interna 192.168.56.0/24 acesse a Internet através do firewall, e por que usar `masquerade` em vez de `snat to IP`?

Resposta:

```
# Criar tabela NAT
nft add table inet nat

# Criar chain POSTROUTING para SNAT
nft add chain inet nat postrouting { type nat hook postrouting priority
srcnat \; }

# Regra de masquerade: tráfego da rede interna saindo pela interface externa
nft add rule inet nat postrouting ip saddr 192.168.56.0/24 oifname "eth0"
masquerade

# Verificar
nft list table inet nat
```

Por que ``masquerade`` em vez de ``snat to <IP>``?

``masquerade`` (SNAT dinâmico): o endereço de origem é substituído automaticamente pelo IP atual da interface de saída. Se o IP externo mudar (DHCP, troca de ISP, failover), a regra continua funcionando sem necessidade de atualização — ideal para ambientes com IP dinâmico ou quando o IP pode variar.

``snat to 203.0.113.10`` (SNAT estático): substitui pelo IP explicitamente definido na regra. Ligeiramente mais performático pois não precisa consultar o IP da interface a cada pacote, mas exige atualização manual da regra quando o IP externo mudar — adequado apenas para ambientes com IP estático fixo.

Em laboratório com VirtualBox/VMware, os IPs de rede host-only podem mudar entre sessões, tornando `masquerade` a escolha mais robusta e prática.

Questão Prática 3

Após configurar o DNAT para redirecionar a porta 8080 do firewall para o servidor web interno (192.168.56.10:80), por que é necessário adicionar também uma regra na chain FORWARD da tabela filter, e qual seria o comando correto?

Resposta:

O DNAT sozinho apenas redireciona o destino do pacote na chain PREROUTING — antes da decisão de roteamento. Após o DNAT, o kernel encaminha o pacote (agora destinado a 192.168.56.10:80) através da chain FORWARD da tabela filter. Se a chain FORWARD tiver política padrão `drop` (boa prática), o pacote será descartado nessa chain antes de chegar ao servidor interno, mesmo que o DNAT tenha sido aplicado corretamente.

Portanto, o DNAT e a regra na FORWARD são duas ações complementares obrigatórias:

```
# 1. DNAT na chain PREROUTING: redirecionar porta 8080 para servidor interno
nft add chain inet nat prerouting { type nat hook prerouting priority dstnat
\; }
nft add rule inet nat prerouting tcp dport 8080 dnat to 192.168.56.10:80

# 2. FORWARD na tabela filter: permitir o pacote atravessar após o DNAT
nft add rule inet firewall forward ip daddr 192.168.56.10 tcp dport 80 ct
state new accept

# Alternativa mais específica (recomendada): limitar por interface
nft add rule inet firewall forward iifname "eth0" oifname "eth1" ip daddr
192.168.56.10 tcp dport 80 accept

# Para o tráfego de retorno do servidor → cliente (já coberto por
established,related):
# A regra ct state established,related accept já deve estar ativa
```

O fluxo completo é: Internet → firewall (eth0:8080) → PREROUTING DNAT → decisão de roteamento → FORWARD filter (nova regra accept) → servidor interno (192.168.56.10:80) → resposta volta via POSTROUTING.

Atividade ISG012-04 - Teoria: Redes Privadas Virtuais (VPN)

Questão 1

Quais são os principais objetivos de aprendizagem propostos para o módulo de Redes Privadas Virtuais (VPN) e quais competências o aluno deve desenvolver ao final do curso?

Resposta:

Os principais objetivos de aprendizagem do módulo ISG012-04 são:

Compreensão teórica dos fundamentos VPN: entender o que é uma VPN, por que ela existe e como ela garante os pilares de segurança — confidencialidade (criptografia), integridade (HMAC), autenticidade (certificados/chaves) e não-repúdio;

Domínio dos tipos de VPN: distinguir e aplicar corretamente VPNs site-to-site (interligação de filiais), remote access (acesso remoto de usuários) e host-to-host, selecionando o tipo adequado para cada cenário corporativo;

Conhecimento dos protocolos: compreender a arquitetura do IPsec (AH, ESP, IKE) e seus modos de operação (transporte e túnel); entender SSL/TLS VPN e suas vantagens de traversabilidade de NAT; e dominar o WireGuard como solução moderna de alto desempenho;

Criptografia aplicada a VPNs: compreender o papel da criptografia assimétrica no estabelecimento de canais seguros, incluindo algoritmos de curvas elípticas (Curve25519) versus RSA, e o conceito de Perfect Forward Secrecy (PFS);

Competência prática: ao final, o aluno deve ser capaz de implementar uma VPN site-to-site utilizando WireGuard entre duas VMs Linux Mint, configurar pares de chaves público/privadas Curve25519, validar a conectividade entre redes privadas e confirmar que o tráfego está criptografado via captura de pacotes (Wireshark/tcpdump).

Questão 2

De que forma as VPNs site-to-site e remote access diferenciam-se quanto ao modelo de deployment, à arquitetura de rede e aos cenários de uso mais adequados para cada uma?

Resposta:

VPN Site-to-Site:

Modelo de deployment: gateways VPN dedicados em cada extremidade (roteadores ou firewalls com capacidade VPN). Os dispositivos dos usuários não têm conhecimento da VPN — ela é transparente para eles.

Arquitetura de rede: conecta duas ou mais **redes completas** (ex.: filial A 10.1.0.0/24 ↔ matriz 10.0.0.0/24). Todo tráfego entre as redes passa automaticamente pelo túnel criptografado sem necessidade de software cliente nos endpoints.

Cenários de uso: interligação permanente de filiais de uma empresa (intranet-based), conexão segura com parceiros de negócio para acesso a sistemas específicos (extranet-based), interligação de data centers em múltiplas regiões.

Gerenciamento: configuração centralizada nos gateways, sem intervenção nos dispositivos dos usuários. Alta disponibilidade via IKE dead-peer-detection e BGP over VPN.

VPN Remote Access:

Modelo de deployment: software cliente instalado no dispositivo do usuário (laptop, smartphone) que se conecta a um servidor VPN central (concentrador VPN ou firewall).

Arquitetura de rede: conecta um **dispositivo individual** à rede corporativa. O dispositivo recebe um endereço IP do pool de endereços corporativos (full tunnel) ou mantém seu IP local roteando apenas tráfego corporativo pelo túnel (split tunnel).

Cenários de uso: acesso remoto de funcionários em home office, trabalho em trânsito (aeroportos, hotéis), proteção em Wi-Fi públicos não confiáveis, acesso de prestadores de serviço a sistemas específicos.

Gerenciamento: distribuição e gerenciamento de clientes VPN, PKI para certificados, autenticação MFA, configuração de políticas de split vs. full tunnel.

Diferença fundamental: site-to-site é infraestrutura estática entre redes fixas; remote access é dinâmico e orientado ao usuário móvel individual.

Questão 3

Explique a arquitetura do IPsec, seus principais protocolos constituintes e como os modos de operação transporte e túnel atendem a diferentes cenários de comunicação segura.

Resposta:

O IPsec (Internet Protocol Security) é um conjunto de protocolos padronizado pela IETF que opera na camada 3 do modelo OSI (rede), oferecendo segurança transparente para todas as aplicações sem necessidade de modificação nas camadas superiores. É composto por três protocolos principais:

AH (Authentication Header): garante autenticidade e integridade do pacote IP completo (incluindo cabeçalho), através de um hash HMAC calculado sobre o pacote. Não criptografa o conteúdo — a confidencialidade não é fornecida pelo AH. Protege contra alterações de pacotes e IP spoofing, mas o payload é legível.

ESP (Encapsulating Security Payload): o componente mais utilizado do IPsec. Fornece confidencialidade (criptografia do payload via AES-GCM, ChaCha20-Poly1305), integridade e autenticidade. É o protocolo padrão para VPNs pois oferece proteção completa.

IKE/IKEv2 (Internet Key Exchange): protocolo de gerenciamento de chaves que automatiza o estabelecimento, manutenção e renovação de SAs (Security Associations) — os parâmetros de criptografia negociados entre os peers. O IKEv2 (mais moderno) opera em duas fases: IKE_SA_INIT (estabelece canal seguro para a negociação) e IKE_AUTH (autentica os peers e cria as Child SAs para o tráfego de dados).

Modo Transporte: protege apenas o payload do pacote IP original, mantendo o cabeçalho IP intacto e visível. Usado para comunicação host-to-host (ex.: dois servidores na mesma organização), onde os endereços reais dos hosts podem ser expostos sem problema de segurança.

Modo Túnel: encapsula o pacote IP inteiro (cabeçalho + payload) dentro de um novo pacote IP com novos cabeçalhos. Os endereços IP originais ficam cifrados dentro do ESP. É o padrão para VPNs site-to-site, pois oculta a

topologia interna das redes conectadas e funciona através de NAT (com NAT-T).

Questão 4

Qual é o papel da criptografia assimétrica no estabelecimento de uma VPN e como os algoritmos modernos de curvas elípticas, como o Curve25519, apresentam vantagens em relação ao RSA tradicional?

Resposta:

A criptografia assimétrica (par de chaves pública/privada) desempenha papel fundamental no **estabelecimento inicial do canal seguro** de uma VPN — especificamente na autenticação dos peers e na troca segura de chaves para a criptografia simétrica que protegerá os dados em trânsito.

O processo típico: cada peer gera um par de chaves (pública + privada). A chave pública é compartilhada com o peer remoto. Durante o handshake IKE ou WireGuard, cada parte usa a chave pública do outro e sua própria chave privada para calcular um segredo compartilhado via troca Diffie-Hellman (DH). Esse segredo é então usado para derivar as chaves simétricas (AES, ChaCha20) que criptografam o tráfego de dados — muito mais eficientes que a criptografia assimétrica para volumes de dados contínuos.

RSA tradicional:

- Baseia-se na dificuldade de fatorar números inteiros grandes
- Para nível de segurança equivalente, requer chaves muito maiores (2048-4096 bits)
- Operações matemáticas mais lentas, especialmente geração e verificação de assinaturas
- Mais sensível a avanços em computação quântica

Curve25519 (criptografia de curvas elípticas — ECC):

- Baseia-se no problema do logaritmo discreto em curvas elípticas
- Oferece o mesmo nível de segurança que RSA-3072 com chaves de apenas 256 bits
- Operações significativamente mais rápidas (handshakes mais ágeis)
- Menor uso de memória e CPU — crítico em dispositivos embarcados e IoT
- Projetado para resistir a ataques de canal lateral (side-channel)
- Adotado pelo WireGuard como algoritmo padrão exclusivo

No WireGuard, cada peer tem um par de chaves Curve25519 (wg genkey / wg pubkey) e o handshake é concluído em ~1 round-trip (vs. múltiplos para IKEv2), resultando em reconexões sub-segundo.

Questão 5

Descreva o processo completo de estabelecimento de um canal seguro em uma VPN, desde a troca inicial de chaves públicas até a criptografia simétrica do tráfego de dados.

Resposta:

O processo de estabelecimento de um canal VPN seguro pode ser descrito nas seguintes etapas, ilustradas com WireGuard (protocolo moderno simplificado):

Etapas 1 — Configuração prévia (out-of-band):

Cada peer gera seu par de chaves:

```
wg genkey | tee privkey | wg pubkey > pubkey
```

As chaves públicas são trocadas entre os administradores por canal seguro (ex.: SSH, e-mail criptografado). Cada peer configura a chave pública do outro em sua configuração.

Etapas 2 — Handshake (Initiator → Responder):

O iniciador envia uma mensagem de handshake contendo: chave pública efêmera (gerada para aquela sessão), identificador de sessão e hash de autenticação calculado usando sua chave privada e a chave pública do responder.

Etapas 3 — Resposta do Handshake:

O responder verifica a autenticidade da mensagem usando a chave pública do iniciador (previamente configurada). Se válida, gera sua própria chave efêmera e responde com os dados necessários para o cálculo do segredo compartilhado.

Etapas 4 — Derivação do segredo compartilhado (ECDH):

Ambos os lados calculam independentemente o mesmo segredo compartilhado via ECDH (Elliptic Curve Diffie-Hellman) usando:

Própria chave privada efêmera + chave pública efêmera do outro

Própria chave privada estática + chave pública estática do outro

Etapas 5 — Derivação de chaves de sessão (KDF):

O segredo ECDH é processado por uma função de derivação de chaves (KDF — HKDF no WireGuard) para gerar duas chaves simétricas independentes: uma para envio (send key) e outra para recepção (receive key).

Etapas 6 — Criptografia do tráfego:

Todo o tráfego subsequente é criptografado com ChaCha20-Poly1305 (autenticado), usando as chaves de sessão derivadas. As chaves efêmeras são descartadas após o handshake (Perfect Forward Secrecy): mesmo que as chaves estáticas sejam comprometidas futuramente, sessões passadas não podem ser descriptografadas.

Renovação: o WireGuard renova as chaves de sessão a cada 180 segundos (renovação automática do handshake), garantindo PFS contínuo.

Questão 6

Por que o modo túnel do IPsec é considerado o padrão para VPNs site-to-site e quais são as principais desvantagens que tornam o IPsec menos competitivo frente a soluções modernas como WireGuard?

Resposta:

O modo túnel do IPsec é o padrão para VPNs site-to-site porque encapsula o pacote IP inteiro (incluindo cabeçalho com endereços internos) dentro de um novo pacote IP com endereços dos gateways VPN. Isso garante: (1) ocultação completa da topologia interna das redes conectadas — os roteadores intermediários na Internet veem apenas os IPs dos gateways, não os endereços internos das filiais; (2) funcionamento transparente através de NAT (com extensão NAT-T na porta UDP 4500); (3) possibilidade de conectar redes inteiras sem configuração em cada host individual.

Desvantagens do IPsec frente ao WireGuard:

Critério	IPsec	WireGuard
Complexidade	Alta: IKE, SA, SPD, SPI, múltiplos protocolos	Baixa: configuração em ~10 linhas
Código-fonte	~400.000 linhas	~4.000 linhas (superfície de

	(strongSwan + kernel)	auditoria mínima)
Tempo de handshake	Múltiplos round-trips (IKE fase 1 + 2)	1 round-trip
Reconexão	Segundos a dezenas de segundos	Sub-segundo (< 100ms)
Traversal de NAT	Requer NAT-T (UDP 4500), complexo	Nativo e transparente (UDP configurável)
Criptografia	Negociável (várias suites, incluindo fracas)	Fixa e moderna (ChaCha20-Poly1305, Curve25519)
Depuração	Extremamente difícil (múltiplos componentes)	Simples (interface wg0 padrão)
Performance	Boa, porém overhead de processamento maior	Muito alta (processamento no kernel, código mínimo)

A complexidade do IPsec é sua maior vulnerabilidade: mais código significa maior superfície de ataque e maior probabilidade de erros de configuração que introduzem falhas de segurança. O WireGuard, com seu código minimalista e criptografia não-negociável (sem cipher-agility), elimina classes inteiras de vulnerabilidades.

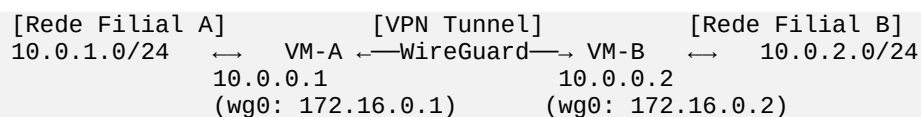
Atividade ISG012-04 - Prática: Implementação de VPN Site-to-Site com WireGuard

Questão Prática 1

Qual é a topologia de laboratório proposta para simular uma VPN site-to-site entre duas filiais e como o VirtualBox deve ser configurado para viabilizar essa prática?

Resposta:

A topologia proposta simula duas filiais interligadas via VPN WireGuard:



Configuração do VirtualBox:

Cada VM (Linux Mint) precisa de duas interfaces de rede:

VM-A (Gateway Filial A):

Adaptador 1: Host-Only Network (vboxnet0) — simula a rede interna da Filial A (10.0.1.0/24)

Adaptador 2: Internal Network "simnet" — simula o link de Internet entre as filiais (10.0.0.0/24)

VM-B (Gateway Filial B):

Adaptador 1: Host-Only Network (vboxnet1) — simula a rede interna da Filial B (10.0.2.0/24)

Adaptador 2: Internal Network "simnet" — mesmo segmento de "Internet" (10.0.0.0/24)

A Internal Network do VirtualBox cria um segmento isolado visível apenas às VMs configuradas com o mesmo nome, simulando o link WAN entre as filiais sem acesso real à Internet.

Instalação do WireGuard (se não presente):

```
sudo apt update && sudo apt install wireguard wireguard-tools -y
```

Questão Prática 2

Quais são os procedimentos técnicos para gerar os pares de chaves Curve25519 e configurar as interfaces WireGuard (wg0) no modo site-to-site nas duas máquinas virtuais?

Resposta:

Em VM-A (Filial A — 10.0.0.1):

```
# Gerar par de chaves
wg genkey | tee /etc/wireguard/privkey-a | wg pubkey > /etc/wireguard/pubkey-a
chmod 600 /etc/wireguard/privkey-a

# Verificar as chaves
cat /etc/wireguard/privkey-a # chave privada (nunca compartilhar)
cat /etc/wireguard/pubkey-a # chave pública (compartilhar com VM-B)

# Criar configuração da interface wg0
cat > /etc/wireguard/wg0.conf << EOF
[Interface]
PrivateKey = $(cat /etc/wireguard/privkey-a)
Address = 172.16.0.1/24
ListenPort = 51820

[Peer]
```

```
PublicKey = <CHAVE_PUBLICA_VM-B>
AllowedIPs = 172.16.0.2/32, 10.0.2.0/24
Endpoint = 10.0.0.2:51820
PersistentKeepalive = 25
EOF
```

Em VM-B (Filial B — 10.0.0.2):

```
wg genkey | tee /etc/wireguard/privkey-b | wg pubkey >
/etc/wireguard/pubkey-b
chmod 600 /etc/wireguard/privkey-b

cat > /etc/wireguard/wg0.conf << EOF
[Interface]
PrivateKey = $(cat /etc/wireguard/privkey-b)
Address = 172.16.0.2/24
ListenPort = 51820

[Peer]
PublicKey = <CHAVE_PUBLICA_VM-A>
AllowedIPs = 172.16.0.1/32, 10.0.1.0/24
Endpoint = 10.0.0.1:51820
PersistentKeepalive = 25
EOF
```

A diretiva `AllowedIPs` define os endereços IP que podem ser enviados/recebidos através deste peer — funciona como ACL de roteamento do WireGuard.

Questão Prática 3

Como devemos proceder para ativar o túnel WireGuard, validar a conectividade entre as redes privadas simuladas e verificar que a criptografia está efetivamente protegendo os dados?

Resposta:

Ativar o túnel em ambas as VMs:

```
# Ativar interface (ambas as VMs)
wg-quick up wg0

# Para ativar automaticamente no boot
systemctl enable wg-quick@wg0
systemctl start wg-quick@wg0
```

Verificar status do túnel:

```
# Em qualquer das VMs
```

```
wg show
# Saída mostra: interface, chave pública, peers, endpoint, handshake
recente, bytes tx/rx
```

Habilitar IP forwarding (para rotear tráfego das redes internas):

```
sysctl -w net.ipv4.ip_forward=1
# Persistente:
echo "net.ipv4.ip_forward=1" >> /etc/sysctl.conf
```

Validar conectividade entre redes privadas:

```
# De VM-A, pingar interface wg0 de VM-B
ping 172.16.0.2

# De um host na rede interna da Filial A (via VM-A como gateway)
# ping para host na rede interna da Filial B
ping 10.0.2.1
```

Verificar que o tráfego está criptografado via tcpdump:

```
# Na interface de "Internet" (eth1 / 10.0.0.0/24)
# Capturar tráfego WireGuard (UDP 51820) — deve aparecer como payload
cifrado
tcpdump -i eth1 udp port 51820 -X

# Na interface wg0 — deve aparecer o tráfego decifrado (ICMP, TCP, etc.)
tcpdump -i wg0 icmp

# Confirmar: na eth1 os dados são ilegíveis (cifrados)
# Na wg0 os dados são legíveis (ICMP echo request/reply)
```

A verificação pelo tcpdump é a prova empírica de que o WireGuard está realmente criptografando — pacotes capturados na interface física (eth1) mostram apenas payload binário aleatório (ChaCha20), enquanto na interface virtual (wg0) o conteúdo é o tráfego real descriptografado.

Conclusão

Esta atividade integrou dois módulos complementares da segurança de perímetro e comunicações seguras. O ISG012-03 estabeleceu a base para proteção da borda da rede com firewalls stateful, arquitetura DMZ e NAT avançado com nftables — demonstrando que a correta configuração de um firewall Linux open-source é equivalente em funcionalidade aos appliances comerciais. O ISG012-04 expandiu essa proteção para além do perímetro físico, com VPNs que garantem confidencialidade e integridade

mesmo em redes públicas não confiáveis.

A comparação entre IPsec e WireGuard evidencia a tendência da área de segurança: soluções mais simples, com código auditável mínimo e criptografia moderna não-negociável, oferecem segurança superior às soluções complexas e legadas. A implementação prática com WireGuard reforça que segurança de alto nível é acessível com ferramentas open-source e conhecimento técnico adequado.